Tailscale policy reference

Use with Phase 3 procedure E for FWR-06/FWT-06 and FF-06/FF-07. The remote user reaches APP1 HTTPS only. This is proposed configuration and testing, not observed operation. Stage I approval must name the separate lab tailnet/identities, existing client, APP1, independent egress, exact changes, validation, final state and rollback. G covers remote lab-root trust; F/D/H/K cover any separately approved host/firewall/listener/test changes. Keep APP1 console and tailnet recovery available.

Independent isolation and identity prerequisites

Purpose and location: under I approval, use the separate lab Tailscale admin console, APP1 and one existing approved lab client. Tailscale forms an encrypted overlay network; its policy must permit only APP1 HTTPS. AD membership and app passwords do not grant overlay access.

1. Confirm **independently isolated** approved egress **before Internet connectivity**, lawful provider terms, separate lab identities/tailnet, supported MFA and recovery. A second NIC, Beryl AX/home-LAN connection or NAT is not proof of that boundary. If this dependency is missing, stop remote work and mark FWT-06 NOT TESTED.

Explicit deny-all baseline

Target / approval: separate lab Tailscale admin console, authorized tailnet administrator, I scope. Expected: saved explicit no-access policy before either enrollment. On a save/validation/identity mismatch retain deny-all and stop; do not restore a permissive default.

1. In the lab admin console **Access controls/policy editor**, save the existing policy privately and replace permissive defaults with the explicit deny-all below **before enrollment**. A blank/omitted policy can retain permissive defaults. Review all grants, ACLs (access-control lists), SSH rules and tag owners; permissions are additive.

DESTRUCTIVE / HIGH-RISK - separate lab Tailscale policy editor, authorized tailnet administrator, I approval. Policy-file content, not commands. This explicit initial policy grants no network or SSH access:

```
{
  "acls": [],
  "grants": [],
  "ssh": []
}
```

Check: the vendor editor validates/saves it and there are no other allows. Tailscale's deny-all examples explain the explicit empty list. On validation failure retain the last reviewed safe policy and stop enrollment.

Device enrollment

Target / approval: APP1 sudo/root console and the one existing approved Windows lab remote client; I scope and an approved verified package source. Expected: two matched device/identity records, with no route or public features. On mismatch remove only the incorrect lab enrollment through recovery; never create an extra permanent device or VM.

1. Use the approved verified selected-version packages from the official Linux installation instructions and Windows client installer. Do not pipe an unreviewed online script into a root shell. Installation/enrollment belongs to I approval and the approved egress path, not this documentation task.

DESTRUCTIVE / HIGH-RISK - APP1 console, sudo/root, I approval. Start the reviewed installed client and authenticate interactively into the separate lab tailnet. No key/token arguments; keep the displayed authentication URL private:

```
sudo tailscale up --accept-routes=false --accept-dns=false --ssh=false
```

Check: complete sign-in with the approved lab identity, compare the **Machines/Devices** entry to APP1, and keep subnet advertisements/exit-node/Funnel/Serve/sharing off. On mismatch stop and remove the unapproved lab enrollment through the authorized recovery plan; never sign in with a production identity.

2. On the existing approved Windows remote client, use the Tailscale tray/menu **Log in** flow with its approved lab identity. Review its client preferences: no exit node, accepted subnet routes or corporate DNS configuration. Compare its Machines entry with the private device record. The remote client must have no direct physical/zone route to APP1 that could falsely make an overlay test pass.

Exact HTTPS-only grant

Target / approval: separate lab policy editor, authorized administrator, exact I-approved enrolled addresses. Expected: only that client device to APP1 TCP 443, with no additive access. On validation failure retain deny-all; an address change requires re-review.

1. Copy the two exact overlay IPv4 addresses into the private stage I record. In the editor replace the initial policy with the following conditional example, replacing both placeholders with those exact addresses. This scopes the enrolled client device as well as APP1; it does not grant every device of a user or an entire subnet.

CONFIGURATION CHANGE - separate lab Tailscale policy editor, authorized administrator. Replace LAB_REMOTE_OVERLAY_IP and LAB_APP_OVERLAY_IP privately; literal symbols are not a valid final policy. No wildcard source/destination or extra grant:

```
{
  "acls": [],
  "grants": [
    {
      "src": ["LAB_REMOTE_OVERLAY_IP"],
      "dst": ["LAB_APP_OVERLAY_IP"],
      "ip": ["tcp:443"]
    }
  ],
  "ssh": []
}
```

Check: the editor validates the exact grant syntax. Tie both addresses to approved device/identity records and inspect absence of additive paths; an address change requires review, never broadening to a range. No Proxmox, OPNsense, DC1, RDP or SSH resource is granted.

Overlay name mapping and host enforcement

Target / approval: approved Windows remote client elevated editor and APP1 console; I-approved mapping/inspection, separate G trust scope and F/D approval for any rule correction. Expected: app.ad.lab.test resolves through the overlay, with independent lab_host filtering intact. Save the hosts file and effective rules privately; on mismatch stop remote use and recover only the identified mapping/rule.

1. On the approved Windows remote client only, use the elevated approved text editor to add the private mapping **LAB_APP_OVERLAY_IP app.ad.lab.test** in **C:\Windows\System32\drivers\etc\hosts**, replacing the address privately. Preserve the original file, avoid duplicate mappings and keep local WIN1 using DC1's zone record. Verify the browser uses the overlay address; do not publish this file.
2. On APP1 compare the active nftables **lab_host** input/forward chains with Tailscale's effective rules. Tailscale manages its own netfilter rules, so an OPNsense permit/deny is insufficient. Keep the Phase 2 independent drop table active and test it; do not select off/nodivert or add forwarding as a shortcut.

READ-ONLY - APP1 or the approved client, local terminal; standard operator where supported. Show current overlay state, with no replacements. The CLI reference documents this inspection:

```
tailscale status
```

Check: only the approved lab enrollment is involved; compare device state to the admin console and actual access checks. Output contains private addresses/identity data and stays private. Status alone is not proof of authorization.

If it fails: retain deny-all access and stop enrollment/use until exact lab identity, device, name mapping, egress and effective host policy agree. Recover only through the approved device/grant removal and saved private settings; do not broaden a rule to make status look connected.

Allowed and denied remote tests

Purpose and location: from the approved remote client under the frozen I/K test scope, prove that only the named application works and that removing authorization stops it. Reuse existing lab people/client; add no permanent device, user or VM.

1. On the approved remote client, trust only the public lab root under its separate approved trust scope. Open **https://app.ad.lab.test/reports/** with valid ava app credentials. Expect normal HTTPS and the report; confirm APP1's access log shows the overlay source, not a local zone bypass.
2. Before revocation, use Reference 06's approved APP1 mock listener. Confirm the administrator control first, then match the remote wrong-port denial to the vendor and host evidence. Confirm the approved client reaches only APP1 HTTPS and clean up the temporary listener and permits. Keep test traffic on lab-owned targets.

3. For the unauthorized-identity check, reuse the same approved lab client under the existing **uma** lab-only provider context if I approval covers that enrollment. Remove/sign out the approved enrollment first, enroll the unauthorized context and verify its distinct device state/address before the test. It must receive no allow. Record the denial and policy evidence. Restore the approved context only through the approved sequence and recheck its current address against the exact grant before testing HTTPS again.

Client and grant revocation

Target / approval: same existing remote client/browser and separate lab console, I/K-approved revocation scope. Expected: a working pre-change HTTPS control, then removal of both client grant and device authorization with existing/fresh requests denied. On failure retain failure evidence, keep the grant removed and use the recovery below; never remove APP1 to manufacture denial.

1. With the approved remote context restored and HTTPS working again, record a change time. Remove its grant and, in **Machines/Devices > exact client menu > Remove**, revoke that specific lab device's authorization. Keep APP1 intact. Vendor removal guidance explains current behavior.
2. Retry an existing browser context with forced network reload and a fresh new request. Both must fail to reach APP1. Compare policy/device state and APP1/host observations; record the exact changes, cache/state treatment and actual time to denial. Re-enrollment requires approval and invalidates any assumption that the previous address remains authorized.

Check: 03 / Test Cases, FWT-06, contains permitted HTTPS, unauthorized identity, wrong listening-port/resource and existing/new revoked-request outcomes. Summarize in **02 / Tailscale Remote Access** and **Access Revocation**. These are separate from the six app-role cases.

If it fails: stop remote access, remove the grant/device under I recovery scope and inspect additive rules, actual source address, client bypass routes, host-chain counters and device state. Never broaden grants, advertise a subnet or add a second remote provider. Restore private name mapping/trust/egress only as authorized.

Record removal time against a separate observer clock, the actual time each denial occurs and any state/cache handling; no revocation-time SLA is defined. A cached page is not a new request. Confirm a network reload in the already authenticated context and a genuinely fresh connection/context; compare admin-console saved policy, exact device removal, APP1 access/error logs and host rules/counters. A lost network path or broken DNS without those observations is insufficient. Do not silently restore the grant or re-enroll after the test. Re-enrollment receives a new device/identity/address review before any grant.

Rule inspection and evidence method

Target / approval: APP1 console, read-only I/F validation; remote client operator and authorized lab tailnet administrator. Expected: vendor policy, enrolled state, resolver/route, host filtering and actual requests agree. If they disagree, stop remote access and use console recovery, retaining failed evidence.

1. In **Access controls**, inspect the saved JSON rather than only the editor buffer: the sole network grant has one exact client source, one exact APP1 destination and **tcp:443**; **acls** and **ssh** are empty. Review every grant/ACL, tag owner and device share. In **Machines**, inspect APP1/client identities, addresses, approval/key state and disabled route/exit-node features. Save evidence privately; plan-specific logging gaps remain explicit.
2. On APP1 inspect the full effective ruleset, including Tailscale-managed chains/backend and **inet lab_host**. The existing host policy accepts overlay TCP 443 and drops other overlay input **before established traffic**; its forward chain drops. Inspect both IPv4/IPv6 forwarding and routes using the existing read-only commands. Preserve unrelated tables and default netfilter operation; no off/nodivert, blanket flush or competing manager.
3. In the remote client's elevated editor use only **C:\Windows\System32\drivers\etc\hosts**, substituting the recorded exact overlay address for **LAB_APP_OVERLAY_IP**. Save its original outside Git, avoid duplicate IPv4/IPv6 mappings and inspect the actual browser connection's remote address in Developer tools > Network. A DNS lookup tool that bypasses hosts is insufficient; WIN1 must keep its DC1 zone A record. Do not grant DC1 DNS to the remote client or trust a certificate for the raw overlay address.
4. Pair working approved HTTPS/Apache role evidence with the unauthorized identity test and known-listening wrong-port/resource test. The unauthorized **uma** provider enrollment must have a distinct inspected device/address and no allow; switching only the browser app account is insufficient. Remove/sign out the approved enrollment first, and restore it only through its approved sequence. Confirm it works again before revocation. Inspect restrictions for DC1, WIN1, Proxmox, OPNsense and other resources; no active protected-network tests.

Use the temporary listener only within the separate applicable D/F/H/I/K approvals. The grant stays on TCP 443. Save the pre-revocation request, control, policy and cleanup evidence for the guide's final network review. If safe scope or a working positive control is absent, leave FWT-06's mandatory subcheck NOT TESTED. A wrong-resource test may use only an approved lab-owned known-listening mock.

Use **03 > Test Cases**, FWT-06.01-.11: isolation/identity/MFA/recovery, enrollment, exact/additive policy, disabled features, host/DNS enforcement, successful HTTPS, unauthorized identity denial, wrong listening port/resource denial, grant/device removal, existing-context denial, fresh-context denial/time. Record operator/date/client/server versions, exact scope, expected/actual results, private evidence IDs, separate observations and final state. Summarize in **02 > Tailscale Remote Access** and **Access Revocation**; failures belong in **04 > Issue Log**. No account/device/route values or raw logs are public evidence by default.

Recovery and version notes

Targets / approval: separate lab admin console, exact existing remote client and APP1 console, named I/G/F/D recovery scope. Preserve last reviewed policy, hosts/trust state, full host rules and private recovery credentials before changes. Keep egress disconnected when isolation is uncertain; stop the affected operation if unexpected protected connectivity appears.

- **Policy or enrollment failure:** save failure evidence; apply the reviewed explicit deny-all baseline and remove the exact unauthorized client enrollment if approved. Verify the saved policy and device state. A saved previous policy may be permissive; do not blindly restore it. Keep APP1 enrolled only if that final state is approved; removing APP1 requires its own scope.

- **Name/host failure:** restore only the saved approved remote hosts entry/file and exact lab-root trust state under G/I recovery scope. Keep WIN1's DC1 DNS configuration. At APP1 console restore only the identified lab_host change using scoped atomic replacement; never erase Tailscale's or other tables. Inspect rules, both address families, forwarding and lack of extra listeners. Do not select off/nodivert, publish routes or allow another port to obtain connectivity.
- **Revocation failure:** retain the removed grant and exact-device revocation, stop remote use, inspect additive grants/shares/tag owners, source identity/address, saved policy propagation, bypass routes and connection state. Record any separately approved state clearing and its time; do not claim immediate removal of downloaded content. Restore permission, trust, egress or enrollment only with explicit recovery/test approval and a new working control.
- **Selected version:** verify official installation, CLI, grant syntax, netfilter modes and device removal for the installed release and provider plan. Inspect all pre-existing client preferences: the enrollment command's flags do not erase earlier advertised routes/exit-node/Serve settings. Windows route/DNS defaults can differ from Linux. Use the selected version's supported preferences to disable route acceptance, DNS override and exit-node use; if controls differ, stop for a reviewed equivalent. Keep Tailscale SSH, Funnel, Serve, public sharing, subnet routing and exit nodes off. Supported MFA/recovery belong to the separate lab identity provider, not AD/app-password reuse.

Physical HP OPNsense constrains underlay/egress; it does not see the complete decrypted overlay decision. Host rules must remain independently effective. This reference adds no production/home trust, public exposure, permanent VM, remote provider or certificate service. Unperformed operational checks stay NOT TESTED; documentation/CI cannot supply owner UAT.